

中华人民共和国通信行业标准

YD/T XXXX.1—XXXX

网络安全产品能力评价体系 第1部分：概念和模型

The capability evaluation system of cybersecurity products — Part 1: Concepts and model

(点击此处添加与国际标准一致性程度的标识)

(报批稿)

XXXX - XX - XX 发布

XXXX - XX - XX 实施

中华人民共和国工业和信息化部 发布

目 次

前 言 II

引 言 III

1 范围 4

2 规范性引用文件 4

3 术语和定义 4

4 缩略语 5

5 安全产品能力评价模型 5

 5.1 安全产品成熟度评价 6

 5.2 安全产品质量评价 6

 5.2.1 通用部分 6

 5.2.2 关键部分 8

参 考 文 献 9

前 言

本文件按照GB/T 1.1—2020《标准化工作导则 第1部分：标准化文件的结构和起草规则》的规定起草。

YD/T XXXX《网络安全产品能力评价体系》计划包括通用方法和具体产品评价方法。其中，通用方法包括如下：

- 第1部分：概念和模型（本文件）；
- 第2部分：指标要求；
- 第3部分：评价方法；
- 第4部分：基于部署方式的安全产品测试方法；
- 第5部分：安全产品研发人员能力评价方法。

具体安全产品评价方法包括：

- 第6部分：欺骗防御（蜜罐）产品评价方法；
- 第7部分：基于零信任架构的业务安全平台评价方法；
- 第8部分：威胁检测与响应产品评价方法；
- 第9部分：攻击面管理产品评价方法；
- 第10部分：企业网络安全措施验证平台评价方法；

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别专利的责任。

本文件由中国通信标准化协会提出并归口。

本文件起草单位：中国信息通信研究院、北京天融信网络安全技术有限公司、郑州信大捷安信息技术股份有限公司、北京奇虎科技有限公司、徐州中国矿业大学大学科技园有限责任公司、北京神州绿盟科技有限公司、长扬科技（北京）股份有限公司、新华三信息安全技术有限公司、腾讯云计算（北京）有限责任公司、高通无线通信技术（中国）有限公司、楚天龙股份有限公司、北京创安恒宇科技有限公司、上海观安信息技术股份有限公司、北京安盟信息技术股份有限公司、北京东方通网信科技有限公司、深圳信息职业技术学院、中兴通讯股份有限公司。

本文件主要起草人：孟楠、戴方芳、董悦、刘起良、沈俊霞、查选、王龔、张静、刘为华、张屹、王森、张可伦、叶晓虎、叶建伟、程潞样、赵华、柴永富、李永波、倪平、王江胜、蒋曲明、方丹、安琪、赵雨秋、谢江、张大伟、张喜龙、陈乔、崔婷婷、卢忱，张运生、游世林、高峰、马伟、刘敏、王继刚。

引 言

网络安全产品正在广泛应用于日益发展的各种业务领域，其有效的使用与网络安全防护效果有着显著的关联，此外，市场上出现了由不同技术的组合、不同安全框架应用的安全产品。网络安全产品分类被进一步碎片化的细分，使得行业企业很难有效选择适用于自身业务的安全产品。帮助行业企业提供一套安全产品成熟度和质量评价的安全产品模型变得至关重要。

编制YD/T XXXX.XXXX《网络安全产品能力评价体系》的总体目标是推动网络安全产业高质量发展，为网络安全技术、产品、框架和方案的创新与应用注入强有力的动能。其定位是推动网络安全技术创新，并助力创新技术赛道安全产品落地和应用，此外，还可以供安全产品开发方、需求方和独立评价方单独使用。本文件拟由以下部分组成：

- 第1部分：概念和模型。提出了网络安全产品能力评价体系和模型，明确了安全产品成熟度、安全产品质量和安全产品能力评价体系标准框架；
- 第2部分：指标要求。确立了网络安全产品能力评价指标要求，包括安全产品成熟度要求和质量要求两部分；
- 第3部分：评价方法。确立了网络安全产品能力评价方法；
- 第4部分：基于部署方式的安全产品测试方法。提供了针对部署方式下的网络安全产品通过第三方测试仪表测试的方法；
- 第5部分：安全产品研发人员能力评价方法。提出了面向安全产品研发人员的知识能力、技能能力等方面评价方法；
- 第6部分至第10部分：分别提出了欺骗防御（蜜罐）产品、基于零信任架构的业务安全平台、威胁检测与响应产品、攻击面管理产品、企业网络安全措施验证平台及具有相关功能的产品技术框架、测试检验和评价方法。

网络安全产品能力评价体系

第 1 部分：概念和模型

1 范围

本文件提出了网络安全产品能力评价体系的概念和模型，明确了安全产品成熟度、安全产品质量和安全产品能力评价体系标准框架。

本文件适用于指导和规范网络安全产品能力评价工作开展和评价体系的构建。

2 规范性引用文件

下列文件中的内容通过文中的规范性引用而构成本文件必不可少的条款。其中，注日期的引用文件，仅该日期对应的版本适用于本文件；不注日期的引用文件，其最新版本（包括所有的修改单）适用于本文件。

GB/T 25069 信息安全技术 术语

GB/T 25000.51-2016 系统与软件工程 系统与软件质量要求和评价（SQuaRE）第51部分：就绪可用软件产品（RUSP）的质量要求和测试细则

3 术语和定义

GB/T 25069、GB/T 25000.51-2016界定的以及下列术语和定义适用于本文件。

3.1

技术就绪水平 technology readiness level scale; TRLS

网络工作分解单元的技术成熟程度。

3.2

就绪可用网络安全产品 ready to use cybersecurity products

无论是否付费，任何用户可以不经开发活动就能获得的具有安全能力的价值交付物或安全运营平台。其形态可以是具备安全能力的独立形态的硬件、软件、云服务等多种形式，也可以是某个系统或平台的安全接口、组件、模块、分/子系统等形式。

[来源：GB/T 25000.51-2016，4.1.6，有修改]

注：在本文件中可简称为“网络安全产品”或“安全产品”。

3.3

网络安全产品成熟度 cyber security products maturity

评价和度量安全产品研发所处发展状态的量化标准，它反映了安全产品对于预期应用目标的满足程度。

注：在本文件中，网络安全产品成熟度简称为“安全产品成熟度”。

3.4

网络安全产品质量 cyber security products quality

在规定条件下使用时，网络安全产品满足功能、性能、易用性、安全性等产品质量属性的能力。

注：在本文件中，网络安全产品质量简称为“安全产品质量”。

3.5

网络安全产品能力 cyber security products capability
包括网络安全产品成熟度和质量，其中基本能力包括通用部分能力和关键部分能力。

4 缩略语

下列缩略语适用于本文件。

RPC	远程过程调用	Remote Procedure Call
XML	可扩展标记语言	Extensible Markup Language

5 安全产品能力评价模型

安全产品能力包括两个维度：一是安全产品成熟度、二是安全产品质量。

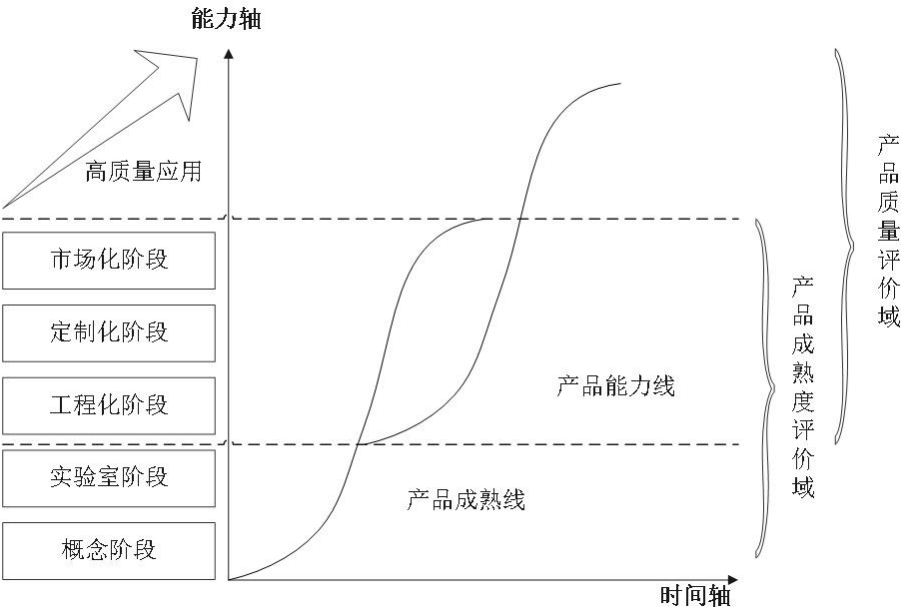


图1 安全产品能力评价模型

安全产品能力评价模型如图1所示。

本模型中横轴是时间轴，指安全产品在不断开发和应用过程中的时间积累。纵轴是能力轴，指安全产品在时间积累中能力等级不断提升，并实现高质量应用的过程积累。

本模型有两条曲线：

- a) 靠左侧的曲线为第一曲线，即安全产品成熟线。该曲线体现了安全产品经历从概念、实验室阶段、工程化阶段、定制化阶段到市场化阶段的不断发展成熟的过程；
- b) 靠右侧的曲线为第二曲线，即安全产品质量线。该曲线体现了安全产品在技术逐渐成熟过程中的质量特征。

网络安全产品能力可以通过安全产品的成熟度和质量叠加度量。网络安全产品评价结论是通过对技术成熟度和质量评价的结果。

注：由于技术成熟度评价不能体现出产品能力，所以在产品成熟度中融入了质量评价，根据产品的成熟阶段，安全产品质量从工程化阶段开始适用。

安全产品质量可由若干个特性组成，包括：

- a) 功能性；
- b) 性能效率；
- c) 兼容性；
- d) 易用性；
- e) 可靠性；
- f) 安全性；
- g) 可维护性；

每个特性由一组相关子特性组成。

5.1 安全产品成熟度评价

安全产品成熟度是技术相对于某个产品或平台所处的发展状态，其客观、量化地反映了技术对于产品预期目标的满足程度。

安全产品成熟度等级是一种基于技术发展成熟规律，采用标准化等级对技术就绪水平进行评测的系统化过程和程序。对安全产品技术成熟度等级的定义是后续进行安全产品能力评价的前提。

安全产品成熟度等级度量和评测特定产品成熟程度的标准和尺度，被划分为5个级别，即五个产品研发阶段：概念产品、实验室产品、工程化产品、定制化产品和市场化产品。其中1级最低，5级最高，如表1所示。

表1 安全产品成熟度等级表

安全产品成熟度等级	等级定义	说明
1级	关键技术原理和制造方案的可行性得到可验证。	此阶段一般为概念产品
2级	分系统或系统研制能力得到相关实验环境验证。	此阶段一般为实验室产品
3级	系统级工程产品通过典型使用环境验证。	此阶段一般为工程化产品
4级	系统级产品通过低速率生产和使用环境示范验证。	此阶段一般为定制化产品
5级	高质量系统级产品，可快速生产，且得到市场验证。	此阶段一般为市场化产品

5.2 安全产品质量评价

5.2.1 通用部分

通用部分是安全产品的质量特性，适用于所有安全产品评价。包括**功能性、性能效率、兼容性、易用性、可靠性、安全性和可维护性**。

5.2.1.1 功能性

功能性包括安全产品的功能完备性、功能正确性、功能适合性和功能的依从性。

- a) 功能完备性：指功能集对指定的任务或用户目标的覆盖程度；
- b) 功能正确性：指安全产品提供具有所需精度的正确结果的程度；
- c) 功能适合性：指功能促使指定的任务和目标实现的程度；
- d) 功能的遵从性：指安全产品遵循与功能性相关的标准、约定或法规以及类似规定的程度。

5.2.1.2 性能效率

性能效率包括安全产品的时间特性、资源利用性、容量、性能效率的依从性。

- a) 时间特性：指安全产品执行其功能时，其响应时间、处理时间及吞吐率满足需求的程度；
- b) 资源利用性：指安全产品执行其功能时，所使用资源数量和类型满足需求的程度；
- c) 容量：指安全产品参数的最大限量满足需求的程度；

- d) 性能效率的遵从性：指安全产品遵循与性能效率相关的标准、约定或法规以及类似规定的程度。

5.2.1.3 兼容性

兼容性包括安全产品的共存性、互操作性和兼容性的依从性。

- a) 共存性：指在与其他安全产品共享通用环境和资源的条件下，安全产品能够有效执行其所需的功能并且不会对其他安全产品造成负面影响的程度；
- b) 互操作性：指两个或多个系统、产品或组件能够交换信息并使用已交换的信息的程度；
- c) 兼容性的遵从性：指安全产品遵循与兼容性相关的标准、约定或法规以及类似规定的程度。

5.2.1.4 易用性

易用性包括安全产品的可辨识性、易学性、易操作性、用户差错防御性、用户界面便利性、易访问性和易用性的依从性。

- a) 可辨识性：指用户能够辨识安全产品是否适合他们的要求的程度；
- b) 易学性：在指定使用环境中，安全产品在有效性、效率、抗风险和满意度特性方面，为了学习使用该产品或系统这一指定目标，可为指定用户使用的程度；
- c) 易操作性：指安全产品具有易于操作和控制的属性的程度；
- d) 用户差错防御性：指安全产品预防用户犯错的程度；
- e) 用户界面便利性：指用户界面简单、提供令人愉悦和满意易于的交互的程度；
- f) 易访问性：指在指定使用环境中，为了达到指定的目标，安全产品被具有最广泛的特征和能力的个体所使用的程度；
- g) 易用性的遵从性：指安全产品遵循与易用性相关的标准、约定或法规以及类似规定的程度。

5.2.1.5 可靠性

可靠性包括安全产品的成熟性、可用性、容错性、易恢复性和可靠性的依从性。

- a) 成熟性：指系统、安全产品或组件在正常运营时满足的可靠性要求的程度；
- b) 可用性：指系统、安全产品或组件在需要使用时能够进行操作和访问的程度；
- c) 容错性：指当存在硬件或软件故障时，系统、安全产品或组件的运行符合预期的程度；
- d) 易恢复性：指发生中断或失效时，安全产品能够恢复直接受影响的数据并重建期望的系统状态的程度；
- e) 可靠性的遵从性：指安全产品遵循与可靠性相关的标准、约定或法规以及类似规定的程度。

5.2.1.6 安全性

安全性保密性、完整性、抗抵赖性、可核查性、真实性和安全性的依从性。

- a) 保密性：指安全产品确保数据只有在被授权时才能被访问的程度；
- b) 完整性：指系统、安全产品或组件防止未授权访问、篡改计算机程序或数据的程度；
- c) 抗抵赖性：指活动或事件发生后可以被证实且不可被否认的程度；
- d) 可核查性：指实体的活动可以被唯一地追溯到该实体的程度；
- e) 真实性：指对象或资源的身份标识能够被证实符合其声明的程度；
- f) 安全性的遵从性：指安全产品遵循与安全性相关的标准、约定或法规以及类似规定的程度。

5.2.1.7 可维护性

可维护性包括安全产品的模块化、可重复性、易分析性、易修改性、易测试性和可维护性的依从性。

- a) 模块化：指由多个独立组件组成的系统或计算机程序，其中一个组件变更对其他组件的影响最小的程度；
- b) 可复用性：指资产能够被用于多个系统，或其他资产建设的程度；
- c) 易分析性：指可以评价预期变更（变更产品或系统的一个或多个部分）对安全产品的影响、诊断产品的缺陷或失效原因、识别待修改部分的有效性和效率的程度。易分析性可以实现包括为安全产品提供机制，以分析其自身故障以及在失效或其他事件前提供报告；
- d) 易修改性：指安全产品可以被有效地、高效地修改，且不会引入缺陷或降低现有产品质量的程度。其实现包括编码、设计、文档和验证的变更。模块化和易分析性会影响到易修改性；
- e) 易测试性：指能够为系统、安全产品或组件建立测试准则，并通过测试执行来确定测试准则是否被满足的有效性和效率的程度；
- f) 可维护性的遵从性：指安全产品遵循与可维护性相关的标准、约定或法规以及类似规定的程度。

5.2.2 关键部分

关键部分是安全产品的核心能力，包括**发现能力、防护能力、分析能力、接口能力和管理能力**。这些能力需根据具体安全产品评价方法匹配对应能力要求。

5.2.2.1 发现能力

发现能力指安全产品对网络安全对象的识别和检测全面性和准确性等，识别检测通常采用数据主动爬取或者流量采集还原的方式实现。网络安全对象包括网络空间资产、漏洞、恶意程序、攻击行为等。识别检测能力适用于对核心功能为识别和检测类产品能力检验。

5.2.2.2 防护能力

防护能力指安全产品对各类网络攻击成功阻断的功能、性能效率和准确率等产品能力。

5.2.2.3 分析能力

分析能力指安全产品对数据分析能力的先进性、效率、准确性等。包含通过流量采集还原的数据或主动爬取的数据的安全分析能力等。

5.2.2.4 接口能力

接口能力指安全产品和除自身之外的模块、组件、系统、产品或平台的数据互联互通能力。包含但不限于XML、RPC、Restful、websocket等。

5.2.2.5 管理能力

管理能力指安全产品对自身管理功能的完善程度。包括用户管理、存储管理、安全管理、配置管理、故障分析等。

参 考 文 献

- [1] GB/T 22900-2009 科学技术研究项目评价通则
 - [2] GB/T 25000.51-2016 系统与软件工程 系统与软件质量要求和评价（SQuaRE）第51部分：就绪可用软件产品（RUSP）的质量要求和测试细则
 - [3] GB/T 25000.40-2018 系统与软件工程 系统与软件质量要求和评价（SQuaRE）第40部分：评价过程
 - [4] GB/T 25000.10-2016 系统与软件工程 系统与软件质量要求和评价（SQuaRE）第10部分：系统与软件质量模型
 - [5] NASA: Technology Readiness Level
 - [6] GJB 7688-2012 《装备技术成熟度等级划分及定义》
-